

Taller: Elige el marco correcto para tu auditoría

Curso: Auditoría de Sistemas (ET0114) — Sesión 3: Normas y estándares internacionales

Docente: Juan Duque

Integrantes del grupo:

- Dahiana Alejandra Alvarez Vinasco
-

1. Organización elegida

Cooperativa de Ahorro y Crédito "CoopAvance"

2. Contexto

CoopAvance es una cooperativa financiera con cerca de 40.000 asociados, que ofrece captación de ahorros, créditos de consumo y libranza, y desde 2023 un canal de banca móvil y billetera digital. Maneja un core financiero (Bantotal), una pasarela de pagos con tarjetas débito, y aplicaciones móviles/web de cara al asociado. Al ser una entidad vigilada por la Superintendencia de la Economía Solidaria, tiene obligaciones regulatorias de reporte financiero y de continuidad del servicio. Sus principales riesgos son: fraude y fuga de información de datos financieros de los asociados, disponibilidad del canal digital (el 70% de las transacciones ya ocurren por app), cumplimiento normativo frente al ente de control, y exposición por el manejo de tarjetas (dato sensible bajo PCI-DSS).

3. Marcos elegidos y orden de aplicación

Orden propuesto: 1) COBIT → 2) ISO/IEC 27001 → 3) PCI-DSS (como referencia de segundo nivel, focalizada)

No se prioriza ITIL como marco principal en este caso, aunque se retoman elementos de gestión de servicio dentro del ciclo de mejora continua.

4. Justificación

COBIT primero, como marco de gobierno. CoopAvance no tiene un problema aislado de seguridad o de servicio: tiene una tensión de gobierno entre TI, el área de riesgo y la Junta, agravada por la exigencia regulatoria de la Superintendencia. COBIT es el marco adecuado como punto de partida porque permite auditar si existe una estructura de gobierno de TI (roles, comités, indicadores) que efectivamente alinee las decisiones tecnológicas —como invertir en

el canal móvil o en seguridad— con los objetivos del negocio y con el cumplimiento regulatorio. Antes de auditar controles técnicos específicos, se necesita evidencia de que la organización *gobierna* la tecnología de forma intencional y no reactiva. Se elige COBIT y no ISO 27001 como punto de entrada porque el riesgo más transversal detectado en el contexto no es "falta de controles de seguridad" sino "falta de alineación entre TI y negocio bajo supervisión regulatoria", que es exactamente el dominio de COBIT (EDM y APO).

ISO/IEC 27001 en segundo lugar, como marco de gestión de seguridad. Una vez auditado el gobierno, el riesgo concreto más crítico de CoopAvance es la protección de datos financieros de los asociados y la disponibilidad del canal digital, que ya es el canal transaccional dominante. ISO 27001 aporta lo que COBIT no detalla: un sistema de gestión de seguridad de la información (SGSI) con controles operativos verificables (Anexo A) sobre control de acceso, criptografía, gestión de incidentes y continuidad. Se ubica después de COBIT porque su implementación efectiva depende de que ya exista un gobierno que la respalde (presupuesto, roles de seguridad, apetito de riesgo definido); auditar ISO 27001 sin haber validado el gobierno correría el riesgo de encontrar controles "de papel" sin sponsor real.

PCI-DSS como referencia focalizada, no como marco integral. CoopAvance procesa tarjetas débito a través de su pasarela de pagos, lo cual la expone a un riesgo muy específico que ni COBIT ni ISO 27001 cubren con el mismo nivel de detalle técnico: el manejo del dato de tarjeta (PAN, CVV) en tránsito y almacenamiento. Por eso se incorpora como una revisión acotada al alcance de la pasarela de pagos, complementaria a los dos marcos anteriores y no como eje central de la auditoría, ya que su alcance normativo es mucho más estrecho que el de la cooperativa en su conjunto.

5. Evidencia propuesta por marco

COBIT

1. Actas del Comité de TI o de Riesgo Tecnológico de los últimos dos periodos, que muestren decisiones de inversión y priorización de proyectos de TI.
2. Matriz o mapa de procesos de TI con responsables (RACI) para al menos los dominios EDM01 (Asegurar el marco de gobierno) y APO12 (Gestión de riesgos).
3. Indicadores (KPI/KRI) de TI reportados a la Junta Directiva o al órgano de control social, con periodicidad definida.

ISO/IEC 27001

1. Política de seguridad de la información vigente, firmada y socializada, junto con el alcance declarado del SGSI.
2. Última evaluación de riesgos de seguridad de la información (metodología, activos críticos identificados, tratamiento de riesgos) y su fecha de actualización.

3. Registro de incidentes de seguridad de los últimos 12 meses, con evidencia de gestión, cierre y lecciones aprendidas.
4. Resultados de la última auditoría interna o externa del SGSI (si ya cuentan con certificación) o del plan de implementación (si están en proceso).

PCI-DSS (alcance: pasarela de pagos)

1. Diagrama de flujo de datos de tarjeta (cardholder data flow) dentro de la pasarela, mostrando dónde se almacena, procesa o transmite el PAN.
2. Certificado o reporte de cumplimiento (AOC/SAQ) vigente de PCI-DSS, o evidencia de contrato con un proveedor de pasarela que sí esté certificado (PCI-DSS Level 1 Service Provider).
3. Resultados del último escaneo de vulnerabilidades (ASV scan) trimestral requerido por el estándar.